🔒 CONFIDENCIAL

Reporte de Vulnerabilidad

Condición de carrera (TOCTOU) en la asignación de ventas — elusión de un límite de negocio

ID del Ticket	**VULN-2026-007**
Activo evaluado	**Aplicación web «El Analista» (Lab El Analista)**
Severidad	**MEDIA** **CVSS v3.1 5.3**
Tipo	**Race Condition / TOCTOU — CWE-362 / CWE-367**
Cliente	**Software Seguro — Laboratorio El Analista**
Analista	**J. M. F. · jmf01111974@gmail.com**
Fecha del reporte	**08 de noviembre de 2026**
Versión	**1.0**

Contenido

1. Resumen Ejecutivo pág. 2
2. Detalles Técnicos pág. 2
3. Métricas CVSS pág. 4
4. Prueba de Concepto (PoC) pág. 4
5. Recomendaciones de Remediación pág. 6
6. Referencias e Historial pág. 7

Este documento contiene información sensible sobre vulnerabilidades de seguridad. Su distribución está restringida al personal autorizado del cliente. Las pruebas se realizaron sobre un entorno de laboratorio con autorización explícita.

1. Resumen Ejecutivo

> Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.

¿Qué encontramos?

El sistema aplica una regla de negocio (un límite sobre cuántas ventas pueden asociarse a un vendedor), pero esa regla **no resiste varias operaciones hechas al mismo tiempo**. Enviando **muchas peticiones en el mismo instante**, el sistema verifica el límite varias veces "en paralelo", antes de haber terminado de aplicar ninguna, y todas pasan. Así se supera la restricción y se asignan más ventas de las permitidas.

¿Por qué importa para el negocio?

Este tipo de falla —una **condición de carrera**— permite **saltarse límites y validaciones** que el negocio da por garantizados. En un sistema de ventas, eso puede traducirse en asignaciones indebidas que afectan comisiones, reportes, objetivos e incentivos, o en fraude interno. El mismo patrón, en otros contextos, habilita usar un cupón más de una vez, retirar saldo de más o exceder cupos. Es un defecto de **integridad de los datos** que erosiona la confianza en las cifras del sistema.

¿Qué tan grave es?

Severidad MEDIA — CVSS 5.3. Requiere una cuenta válida y cierta precisión de temporización, pero con herramientas estándar (Burp Suite) la explotación es sencilla y repetible. Durante la prueba se enviaron peticiones simultáneas que eludieron el control y permitieron asociar las ventas más allá del límite, obteniéndose el código de verificación del laboratorio.

¿Qué hay que hacer?

Hacer que la comprobación del límite y la acción sean **una sola operación indivisible (atómica)** en la base de datos, con bloqueos o restricciones que impidan que dos peticiones concurrentes pasen el control a la vez. Es una corrección acotada y de alto valor.

Riesgo	Probabilidad	Impacto	Urgencia de acción
Elusión de un límite de negocio por envío concurrente de peticiones (condición de carrera)	Media	Medio	Alta

2. Detalles Técnicos

> Audiencia: equipo de desarrollo y administradores de la plataforma.

2.1 Descripción de la vulnerabilidad

La operación de asignación de ventas valida una condición (el límite por vendedor) y luego ejecuta la acción en pasos **no atómicos**: la comprobación y la escritura no ocurren dentro de una misma transacción con bloqueo. Cuando varias peticiones llegan de forma **concurrente**, todas leen el mismo estado inicial, todas superan la validación y todas escriben, excediendo el límite. Es un caso clásico de *Time-of-Check to Time-of-Use* (TOCTOU): entre el momento en que se comprueba la condición y el momento en que se usa el resultado, el estado cambia.

La explotación se logra reduciendo al mínimo la diferencia de tiempos de llegada entre peticiones. Con HTTP/2, Burp Suite emplea el **single-packet attack** (hasta ~20-30 peticiones en un único paquete TCP, eliminando el jitter de red); con HTTP/1.1 usa la sincronización por último byte (*last-byte sync*). Ambas técnicas hacen el ataque fiable y repetible.

2.2 Flujo del ataque

- El atacante (un analista autenticado) captura la petición que asocia una venta a un vendedor.
- La envía a **Repeater** y la duplica en varias pestañas; las agrupa en un *tab group*.
- Ejecuta **«Send group in parallel»**: Burp dispara todas las peticiones en la misma ventana de milisegundos.
- Varias peticiones superan la validación del límite antes de que ninguna termine de aplicarse; el estado final excede lo permitido.
- La página refleja la asignación completa y el laboratorio entrega el código de verificación.

2.3 Clasificación

Categoría	Referencia
Tipo (CWE)	CWE-362 — Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') · CWE-367 — Time-of-check Time-of-use (TOCTOU) Race Condition · CWE-841 — Improper Enforcement of Behavioral Workflow
OWASP Top 10 (2021)	A04:2021 — Insecure Design (falta de control de concurrencia en la lógica de negocio)
OWASP API Security Top 10 (2023)	API6:2023 — Unrestricted Access to Sensitive Business Flows
CVE	No aplica (defecto de diseño/implementación de la aplicación, no de un componente de terceros)

2.4 Activos y alcance afectado

Elemento	Detalle
Aplicación	«El Analista» (Lab El Analista)
Host	`chl-<instancia>-el-analista.softwareseguro.com.ar` (el subdominio se asigna por instancia/sesión)
Superficie afectada	Endpoint de asignación de ventas a vendedor (acción con límite de negocio verificado de forma no atómica)
Autenticación	Sesión de analista autenticado
Dato involucrado	Asignación de ventas a vendedores (afecta comisiones, reportes e incentivos)
Alcance	Integridad de los datos de ventas/asignaciones de la plataforma

2.5 Causa raíz

La lógica aplica un patrón **comprobar-luego-actuar** sin control de concurrencia: lee el estado, valida el límite y escribe, en operaciones separadas y sin bloqueo sobre el recurso compartido. No existe una barrera (transacción serializada, bloqueo pesimista/optimista o restricción en base de datos) que garantice que solo una de las

peticiones concurrentes supere la validación. El resultado depende del orden de ejecución, lo que un atacante fuerza enviando peticiones simultáneas.

3. Métricas CVSS

Puntuación objetiva y reproducible del riesgo técnico, según CVSS v3.1.

CVSS Base Score	Severidad	Vector
5.3	MEDIA	`CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N`

Desglose del vector (métricas base)

Métrica	Valor	Justificación
Attack Vector (AV)	**Network (N)**	La operación se explota de forma remota a través de Internet (HTTP/HTTPS).
Attack Complexity (AC)	**High (H)**	El éxito depende de ganar una ventana de temporización (condición de carrera), fuera del control total del atacante.
Privileges Required (PR)	**Low (L)**	Se requiere una cuenta de analista autenticada.
User Interaction (UI)	**None (N)**	No requiere que ninguna víctima realice acción alguna.
Scope (S)	**Unchanged (U)**	El impacto permanece dentro de la misma aplicación/autoridad de seguridad.
Confidentiality (C)	**None (N)**	No se expone información confidencial.
Integrity (I)	**High (H)**	Permite eludir una regla de negocio y dejar los datos de asignación en un estado no permitido.
Availability (A)	**None (N)**	No afecta la disponibilidad del servicio.

Nota de criterio: se asigna **AC:H** por tratarse de una condición de carrera dependiente de temporización. No obstante, el **single-packet attack** vuelve la explotación altamente fiable; evaluado con `AC:L`, el puntaje asciende a **6.4**, que permanece en el rango de severidad Media. El impacto real debe ajustarse según qué protege el límite eludido (p. ej. si implica movimientos económicos o de inventario, la severidad aumenta).

Verificable en la calculadora oficial: https://www.first.org/cvss/calculator/3.1

4. Prueba de Concepto (PoC)

Reproducción paso a paso. Cualquier técnico con una cuenta del laboratorio y Burp Suite puede replicar el hallazgo.

4.1 Requisitos previos

- Sesión de analista autenticada en el laboratorio.
- Burp Suite (Proxy + Repeater; opcionalmente la extensión Turbo Intruder).
- El sitio preferentemente sobre HTTP/2 (habilita el single-packet attack).

4.2 Pasos de reproducción (Burp Repeater)

Paso 1 — Capturar la petición de asignación. Con el proxy activo, realizar una asignación de venta a vendedor y capturar la petición correspondiente (p. ej. `POST /api/ventas/asignar` con el `venta_id` y `vendedor_id`).

Paso 2 — Enviar a Repeater y duplicar. Clic derecho → `Send to Repeater` (Ctrl+R). Duplicar la pestaña varias veces (p. ej. 20–30): clic derecho sobre la pestaña → `Duplicate tab`.

Paso 3 — Agrupar y lanzar en paralelo. Seleccionar todas las pestañas → clic derecho → `Create tab group`. En el botón de envío elegir **«Send group in parallel»**.

```
# Burp selecciona automáticamente la técnica:
#   HTTP/2  -> single-packet attack (hasta ~20-30 peticiones en 1 paquete TCP)
#   HTTP/1.1 -> last-byte sync
# Objetivo: minimizar la diferencia de tiempos de llegada entre peticiones
```

Evidencia 1 — El grupo de peticiones se dispara en la misma ventana de milisegundos.

Paso 4 — Verificar el resultado. Revisar las respuestas: varias devuelven éxito donde el límite debería haber permitido solo una. Recargar la página para confirmar el estado final.

```
# Se asocian las ventas más allá del límite -> el control fue eludido
# Código de verificación obtenido: db1ab6987f0624b58ae72fa69aba4d14
```

Evidencia 2 — Objetivo cumplido: la asignación supera el límite de negocio y se obtiene el código, confirmando la condición de carrera.

4.3 Alternativa — Turbo Intruder (mayor control)

Para más volumen o precisión, enviar la petición a Turbo Intruder y liberar todas las peticiones a la vez con un `gate`:

```
def queueRequests(target, wordlists):
    engine = RequestEngine(endpoint=target.endpoint, concurrentConnections=1,
                           engine=Engine.BURP2)
    for i in range(30):
        engine.queue(target.req, gate='race1')   # encola, no envía
    engine.openGate('race1')                      # libera todas simultáneamente
```

4.4 Resultado esperado vs. obtenido

Esperado (sistema seguro)	Obtenido (sistema vulnerable)
Solo una operación supera el límite; las peticiones concurrentes restantes se rechazan (la validación es atómica).	Varias peticiones concurrentes superan el límite y la asignación queda en un estado no permitido.

> ⚠ Nota ética: la PoC se ejecutó únicamente sobre el entorno de laboratorio autorizado, con el volumen mínimo necesario para demostrar el riesgo. En producción conviene limitar la cantidad de peticiones y revertir cualquier estado alterado tras la prueba.

5. Recomendaciones de Remediación

> Audiencia: equipo de desarrollo que implementará la corrección.

5.1 Solución recomendada (prioritaria)

Hacer atómica la comprobación y la acción. La validación del límite y la escritura deben ocurrir dentro de una misma transacción, con un bloqueo que impida que dos peticiones concurrentes lean el mismo estado.

```
# VULNERABLE: comprobar-luego-actuar sin bloqueo (TOCTOU)
cant = Venta.objects.filter(vendedor_id=vid).count()   # lectura
if cant < LIMITE:                                       # validación
    Venta.objects.create(vendedor_id=vid, ...)          # escritura (ventana de carrera)

# CORREGIDO: transacción + bloqueo pesimista sobre el recurso compartido
with transaction.atomic():
    vendedor = Vendedor.objects.select_for_update().get(id=vid)   # SELECT ... FOR UPDATE
    if vendedor.ventas_asignadas >= LIMITE:
        raise LimiteExcedido()
    vendedor.ventas_asignadas += 1
    vendedor.save()
    Venta.objects.create(vendedor=vendedor, ...)
```

Reforzar con una restricción en base de datos. Cuando el límite pueda expresarse como invariante (p. ej. unicidad o cota), declararlo en la base de datos como última línea de defensa (restricciones `UNIQUE` / `CHECK`), de modo que ni siquiera una carrera pueda violarlo.

5.2 Mitigaciones y buenas prácticas

- **Claves de idempotencia**: aceptar un identificador único por operación para que reintentos/duplicados no se apliquen dos veces.
- **Bloqueo optimista** (columna de versión) como alternativa al pesimista cuando la contención es baja.
- **Rate limiting** por usuario/operación como defensa en profundidad frente a ráfagas concurrentes.
- **Serializar** operaciones sensibles por recurso (p. ej. colas o locks distribuidos) cuando la base de datos no basta.
- **Pruebas de concurrencia** en la batería automatizada: lanzar N operaciones en paralelo y verificar que el invariante se mantiene.

5.3 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
Envolver comprobación+acción en transacción con `select_for_update`	Equipo de desarrollo	Alta	Inmediato	Pendiente
Añadir restricción en base de datos que materialice el límite	Equipo de desarrollo	Alta	7–15 días	Pendiente
Rate limiting y claves de idempotencia en operaciones sensibles	Infraestructura / Desarrollo	Media	15–30 días	Pendiente
Test de concurrencia en CI (N en paralelo → invariante intacto)	QA / Seguridad	Alta	Con el fix	Pendiente

Re-test de verificación	Analista de seguridad	Alta	Tras el fix	Pendiente

5.4 Verificación (re-test)

Repetir el ataque con «Send group in parallel» (y con Turbo Intruder) sobre la operación corregida. El criterio de aceptación es que, ante N peticiones concurrentes, **solo la cantidad permitida** se aplique y el resto se rechace, manteniéndose el invariante del límite. Confirmar además que la operación legítima (secuencial) sigue funcionando con normalidad.

> ✔ Criterio de cierre: el ticket se marca como *Cerrado* cuando el re-test confirma que el envío concurrente ya no permite exceder el límite, sin regresiones en la funcionalidad legítima.

6. Referencias e Historial

Referencias

- OWASP Top 10 (2021) — A04 Insecure Design: https://owasp.org/Top10/A04_2021-Insecure_Design/
- OWASP API Security Top 10 (2023) — API6 Unrestricted Access to Sensitive Business Flows: https://owasp.org/API-Security/editions/2023/en/0xa6-unrestricted-access-to-sensitive-business-flows/
- CWE-362 — Race Condition: https://cwe.mitre.org/data/definitions/362.html
- CWE-367 — Time-of-check Time-of-use (TOCTOU) Race Condition: https://cwe.mitre.org/data/definitions/367.html
- PortSwigger Web Security Academy — Race conditions: https://portswigger.net/web-security/race-conditions
- OWASP WSTG — Testing for Race Conditions: https://owasp.org/www-project-web-security-testing-guide/
- CVSS v3.1 Calculator (FIRST): https://www.first.org/cvss/calculator/3.1

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-11-08	J. M. F.	Creación del reporte: condición de carrera (TOCTOU) que permite eludir un límite de negocio en la asignación de ventas.

🔒 Documento confidencial — uso interno / cliente autorizado únicamente. Las pruebas se realizaron en un entorno de laboratorio con autorización explícita.